



Report on SOC core concept

1. SOC Fundamentals and Operations

- A Security Operations Center (SOC) is responsible for continuous monitoring, detection, and response to security threats within an organization. It ensures system security by analyzing logs, investigating alerts, and responding to incidents in real time.

- **Purpose of a SOC:**

- A Security Operations Center (SOC) is a centralized team responsible for continuously monitoring, detecting, analyzing, and responding to cybersecurity threats within an organization. The primary goal of a SOC is to protect systems, networks, and sensitive data from cyberattacks and unauthorized activities.

1. Proactive threat detection

- SOC teams continuously monitor security events and logs to identify suspicious activities before they become major incidents. This proactive approach helps organizations reduce the impact of attacks such as malware infections, phishing attempts, brute-force attacks, and unauthorized access.

2. Incident Response

- When a security incident occurs, the SOC team investigates, contains, and mitigates the threat. Incident response involves identifying the root cause, minimizing damage, and restoring normal operations.

3. Continuous Monitoring

- SOC operations run 24/7 to ensure constant visibility of organizational systems and networks. Continuous monitoring helps identify threats in real time and improves overall security posture.



- **Roles in a SOC**

SOC teams are typically divided into multiple levels based on expertise and responsibilities.

1. Tier 1 Analyst

- Tier 1 analysts are the first responders who monitor SIEM dashboards and investigate initial alerts.

- **Responsibilities of a tier 1 analyst :**

- Monitor alerts
- Identify false positives
- Escalate serious incidents
- Document security events

- **Skills required :**

- Basic networking knowledge
- SIEM monitoring
- Log analysis

2. Tier 2 Analyst

- Tier 2 analysts conduct deeper investigations and validate security incidents.

- **Responsibilities of a tier 2 analyst :**

- Analyze suspicious activities
- Investigate malware infections
- Correlate multiple events
- Contain threats

- **Skills required :**

- Threat analysis
- Incident investigation
- Malware behavior analysis



3. Tier 3 Analyst

- Tier 3 analysts are highly experienced security professionals handling advanced threats.
- **Responsibilities of a tier 3 analyst:**
 - Advanced threat hunting
 - Malware reverse engineering
 - Detection engineering
 - Security improvement strategies
- **Skills required :**
 - Advanced cybersecurity expertise
 - Scripting and automation
 - Threat intelligence analysis

4. SOC Manager

- The SOC Manager oversees daily SOC operations and coordinates the security team.
- **Responsibilities of soc manager :**
 - Team management
 - Incident coordination
 - Policy implementation
 - Reporting to management
- **Skills required :**
 - Leadership
 - Communication
 - Incident management

5 .Threat Hunter

- Threat hunters proactively search for hidden threats that automated systems may miss.
- **Responsibilities of Threat Hunter:**



- Search for attacker behavior
- Investigate anomalies
- Identify advanced persistent threats (APTs)
- Improve detection rules

- **Skills required :**

- Threat intelligence
- Advanced log analysis
- Knowledge of attacker tactics and techniques

- **Key Functions of a SOC**

1. Log Analysis

- Log analysis involves collecting and examining logs generated by systems, servers, firewalls, and applications.
- It detects suspicious activities, Supports investigations and Helps identify attack pattern.

- **Common Log Sources:**

- Windows Event Logs
- Syslog
- Firewall logs
- Web server logs

2. Alert Triage

- Alert triage is the process of reviewing and prioritizing alerts based on severity and potential impact.
- It reduces false positives , Helps prioritize critical threats and Improves SOC efficiency

3. Alert Triage Process:

- Validate the alert -> Determine severity --> Investigate affected systems
- Escalate if necessary



4. Threat Intelligence Integration

- Threat intelligence integration uses external threat data to improve detection and response capabilities.
- It includes Malicious IP addresses , Indicators of compromise (IOCs), Malware signatures, Threat actor tactics
- Microsoft and IBM security solutions integrate threat intelligence with SIEM and XDR platforms to enhance detection accuracy.

• NIST Cybersecurity Framework (CSF)

- The NIST Cybersecurity Framework provides guidelines for managing cybersecurity risks and improving organizational security posture.

1. Identify

- Understanding organizational assets, risks, and vulnerabilities.

2. Protect

- Implementing safeguards to reduce cybersecurity risks.

3. Detect

- Monitoring systems to identify cybersecurity incidents.

4. Respond

- Taking action during a security incident.

5. Recover

- Restoring systems and improving resilience after incidents.

• MITRE ATT&CK Framework

- The MITRE ATT&CK framework is a globally accessible knowledge base of attacker tactics, techniques, and procedures (TTPs).
- The framework helps organizations to :
 - Understand attacker behavior .
 - Improve threat detection
 - Conduct threat hunting .
 - Develop incident response strategies.



- **Summary**

- A Security Operations Center (SOC) is responsible for continuous monitoring, detection, and response to security threats within an organization. It ensures system security by analyzing logs, investigating alerts, and responding to incidents in real time.
- SOC operations involve multiple roles including Tier 1 analysts for initial monitoring, Tier 2 analysts for investigation, and Tier 3 analysts for advanced threat hunting. The SOC manager oversees operations and ensures effective incident response.
- The key functions of a SOC include continuous log monitoring, alert triage, incident investigation, and integration of threat intelligence to detect and respond to security threats.
- The SOC workflow begins with detection of suspicious activity, followed by triage to prioritize alerts. Investigation is performed by analyzing logs and network traffic, and appropriate response actions are taken to mitigate the threat.
- SOC operations are often guided by frameworks such as the NIST Cybersecurity Framework and MITRE ATT&CK, which help standardize threat detection and response processes.

2. Security Monitoring Basics

- security monitoring is a core function of a Security Operations Center (SOC). It involves continuously observing systems, networks, applications, and user activities to detect suspicious behavior, security incidents, and policy violations. Effective security monitoring helps organizations identify cyber threats early and respond before significant damage occurs.

- **Objective of Security Monitoring**

- Security monitoring involves continuous observation of network traffic and system logs to detect anomalies, unauthorized access, and potential security threats.

1. Detect Anomalies

- An anomaly is any unusual behavior that deviates from normal system or network activity. Security monitoring tools analyze patterns and identify unexpected events that may indicate cyberattacks or system misuse.
- Anomaly detection helps identify Insider threats, Malware infections, Unauthorized activities.



- Anomalies include :
 - Sudden increase in failed login attempts
 - Unusual outbound network traffic
 - Unexpected administrator account activity
 - Large data transfers during non-business hours.

2. Detect Unauthorized Access

- Unauthorized access occurs when an attacker or unauthorized user gains access to systems, applications, or sensitive data.
- Help to prevent Account compromise, Data breaches and Lateral movement within networks.
- Indicators of Unauthorized Access:
 - Login attempts from unknown IP addresses
 - Access outside normal working hours
 - Multiple failed login attempts followed by successful login
 - Privilege escalation activities

3. Detect Policy Violations

- Organizations establish security policies to ensure safe system usage. Security monitoring helps identify activities that violate these policies.
- Installation of unauthorized software, Accessing restricted websites, Use of weak passwords, Unauthorized USB device connections this is some example of policy violations.

• **Security Monitoring Tools**

1. SIEM (Security Information and Event Management)

- A SIEM platform collects, normalizes, stores, correlates, and analyzes logs from multiple sources to detect security threats.
- Splunk and ElasticSearch is a of the SIEM tool.
- A SIEM can correlate failed login, suspicious IP activity, malware alerts.
- Functions of SIEM:
 - Centralized log collection
 - Real-time alert generation
 - Event correlation



- Incident investigation
- Dashboard visualization.

- Benefits:
 - Centralized visibility
 - Faster threat detection
 - Improved incident response

2. Network Traffic Analyzers

- Network traffic analyzers monitor and inspect network packets to identify suspicious communications and malicious activities.
- Wireshark is a one of the tool of Network Traffic Analyzer.
- Wireshark can identify Suspicious DNS request, Unencrypted credentials, Malware command-and-control traffic.

- Functions:
 - Packet capture and analysis
 - Protocol inspection
 - Network troubleshooting
 - Detection of malicious traffic.

• Key Metrics in Security Monitoring

- Key metrics in security monitoring include false positives, false negatives, and mean time to detect (MTTD), which help evaluate the effectiveness of monitoring systems.

1. False Positives

- A false positive occurs when a security tool incorrectly identifies normal activity as malicious.
- E.g. legitimate employee login is mistakenly flagged as suspicious.
- It wastes analyst time, Creates alert fatigue, Reduces operational efficiency.
- Our goal is to Reduce false positives while maintaining accurate threat detection.

2. False Negatives

- A false negative occurs when malicious activity is not detected by the security system.
- E.g. A malware infection occurs but no alert is generated.



- It Undetected attacks, Increased organizational risk, Delayed incident response

3. Mean Time to Detect (MTTD)

- MTTD measures the average time required to identify a security incident after it occurs.
- It indicates Faster threat detection, Better monitoring efficiency and Reduced attack impact.

- **Setting a lab environment with Elasticsearch .**

- The objective of this lab is to build a basic Security Operations Center (SOC) monitoring pipeline using the Elastic Stack. The lab demonstrates how logs are collected from a Windows machine, forwarded through Logstash, stored in Elasticsearch, and analyzed in Kibana for security monitoring purposes.

- **Commands for installation and configuration of Elasticsearch :**

1. `sudo dpkg -i elasticsearch-8.19.15-amd64.deb`

to download a elastic search

2. `sudo systemctl enable elasticsearch`

to enable a elastic search

3. `sudo systemctl start elasticsearch`

- to start a elastic search

4. `sudo systemctl status elasticsearch`

- to verify elastic search is running

5. `sudo journalctl -u elasticsearch -f`

to view logs in elastic search

6. `sudo dpkg -i kibana-8.19.15-amd64.deb`



- to install kibana

7. sudo systemctl start kibana

- to start kibana

8. sudo dpkg -i logstash-8.19.15-amd64.deb

- to install logstash

9. sudo nano /etc/logstash/conf.d/winlogbeat.conf

- to config winlogbeat in logstash.

10. sudo systemctl enable logstash

to enable logstash

11. sudo systemctl start logstash

to start a logstash

5. .\install-service-winlogbeat.ps1

To install winlogbeat service in windows .

6. Start-Service winlogbeat

To Start winlogbeat service

7. curl -X GET "localhost:9200/winlogbeat-logs/_search?pretty"

to verify logs In elastic search

8. sudo nano apache.conf

- to config apache log normalization in logstash

9. sudo /usr/share/logstash/bin/logstash -f apache.conf



- to run apache pipeline

- **Lab components**

1. **Ubuntu VM**

- Hosts Elastic Stack components

2. **Elasticsearch**

- Stores and indexes logs

3. **Kibana**

- Visualizes and analyzes logs

4. **Logstash**

- Processes and forwards logs

5. **Winlogbeat**

- Collects Windows Event Logs

6. **Windows Machine**

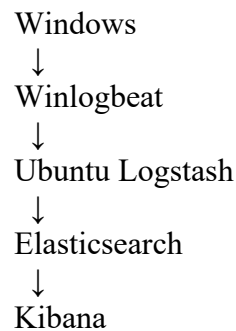
- Generates Windows Security Logs

- Windows Security Event Logs were collected using Winlogbeat and forwarded to Logstash running on Ubuntu. Logstash processed and normalized the logs before sending them to Elasticsearch for analysis in Kibana. Failed authentication events (Event ID 4625) were queried using KQL to demonstrate security monitoring and log analysis workflows.
- Elastic Stack components including Elasticsearch, Kibana, and Logstash were installed on an Ubuntu virtual machine to create a centralized SIEM environment. Elasticsearch was configured for log storage, Kibana for visualization and analysis, and Logstash for log processing and normalization.
- Elasticsearch acts as the central storage engine for all collected logs. It indexes logs so that security analysts can search and analyze events quickly.
- Kibana provides a graphical interface for viewing and analyzing logs stored in Elasticsearch.
- Logstash acts as the processing layer in the SOC pipeline.
- Winlogbeat collects Windows Event Logs and securely forwards them to Logstash.
- Logstash converted incoming logs into structured JSON documents before storing them in Elasticsearch.

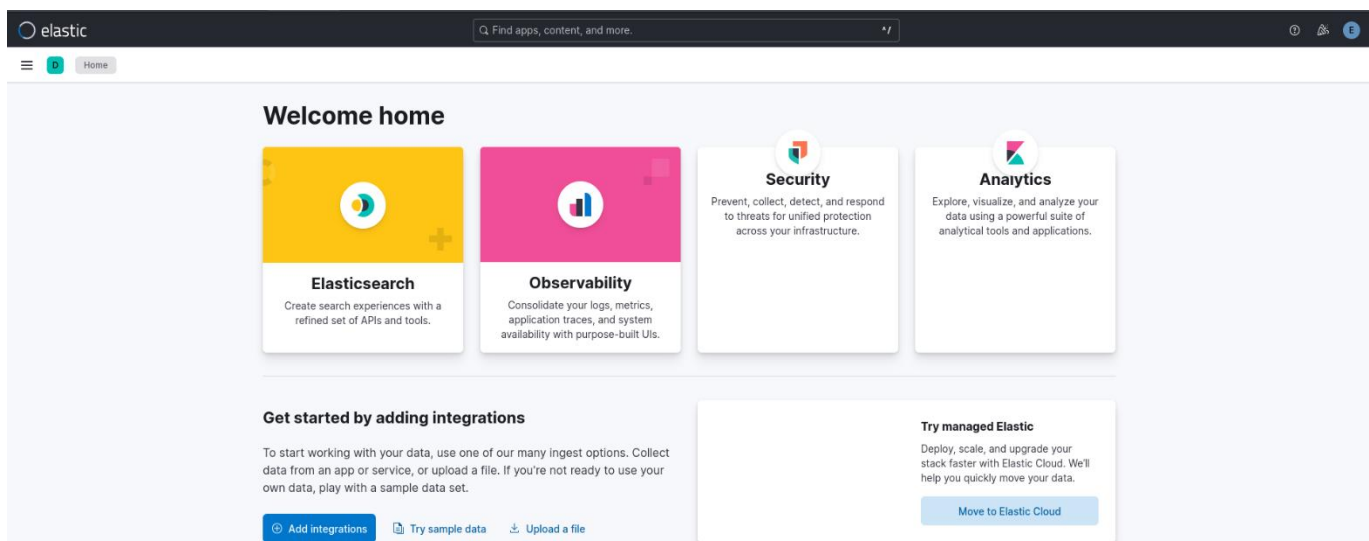


- Normalization ensures logs from different sources follow a consistent format.

- **Overall architecture**



- **kibana dashboard**



- **Analyzing Network Traffic**

- Network traffic was captured using Wireshark, focusing on SSH communication over port 22. Repeated connection attempts from a single source IP were observed, indicating suspicious behavior consistent with a brute-force attack.
- Authentication logs were analyzed in Kibana by filtering failed login attempts. A large number of repeated failures from a single IP address were identified, indicating a brute-force attack pattern.



- The suspicious activity observed in network traffic was validated by corresponding log entries, demonstrating how security monitoring combines both network and log analysis for accurate threat detection.

- **SSH brute-force attack performed from Kali Linux targeting Metasploitable system.**

```
root@kali:~/home/kali
# hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://10.238.221.32
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal
purposes (this is non-binding, these ** ignore laws and ethics anyway).

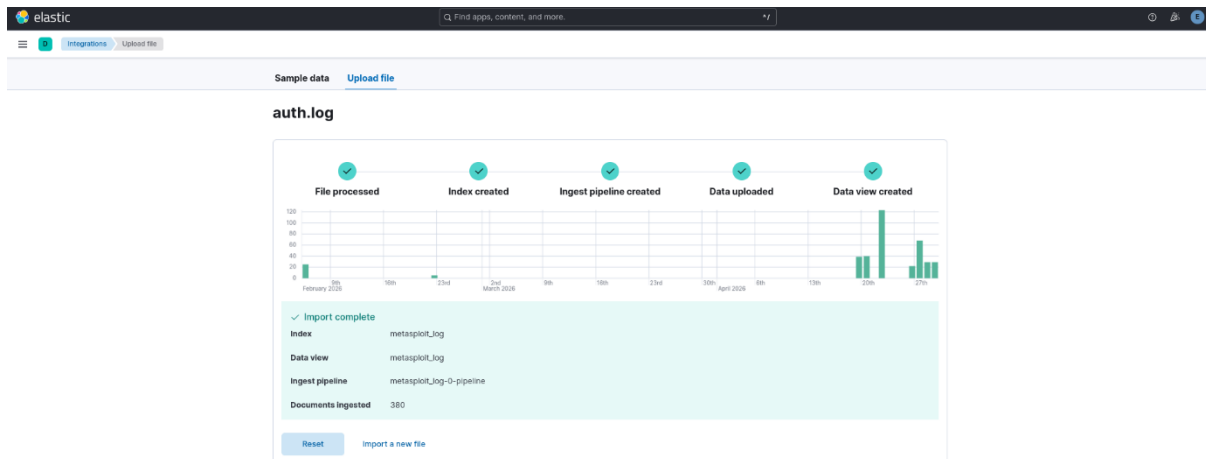
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-30 10:09:01
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
```

- **Ssh login attempts captured by wireshark:**

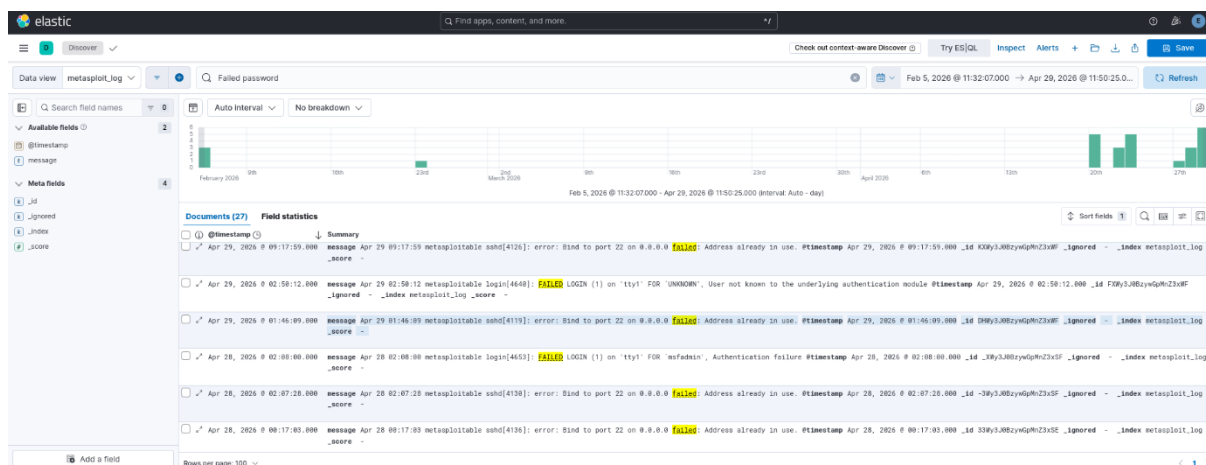
No.	Time	Source	Destination	Protocol	Length	Info
874	48.199842789	10.238.221.118	10.238.221.32	TCP	66	55688 → 22 [FIN, ACK] Seq=1602 Ack=823 Win=64512 Len=0 TSval=150865137 TSecr=475390
875	48.200059507	10.238.221.32	10.238.221.118	TCP	66	22 → 55688 [FIN, ACK] Seq=823 Ack=1602 Win=8704 Len=0 TSval=475390 TSecr=150865134
876	48.200482504	10.238.221.118	10.238.221.32	TCP	66	55688 → 22 [ACK] Seq=1603 Ack=824 Win=64512 Len=0 TSval=150865137 TSecr=475390
877	48.200950899	10.238.221.32	10.238.221.118	TCP	66	22 → 55688 [ACK] Seq=824 Ack=1603 Win=8704 Len=0 TSval=475390 TSecr=150865137
878	48.211755766	10.238.221.118	10.238.221.32	TCP	74	55702 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=150865149 TSecr=0 WS=1024
879	48.212326098	10.238.221.32	10.238.221.118	TCP	74	22 → 55702 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=475391 TSecr=150865149 WS=32
880	48.21309751	10.238.221.118	10.238.221.32	TCP	66	55702 → 22 [ACK] Seq=1 Ack=1 Win=64512 Len=0 TSval=150865150 TSecr=475391
881	48.213575782	10.238.221.118	10.238.221.32	SSHv2	99	Client: Protocol (SSH-2.0-OpenSSH_10.2p1 Debian-3)
882	48.213978706	10.238.221.32	10.238.221.118	TCP	66	22 → 55702 [ACK] Seq=1 Ack=34 Win=5792 Len=0 TSval=475392 TSecr=150865150
883	48.218764764	10.238.221.32	10.238.221.118	SSHv2	104	Server: Protocol (SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1)
884	48.218879488	10.238.221.118	10.238.221.32	TCP	66	55702 → 22 [ACK] Seq=34 Ack=39 Win=64512 Len=0 TSval=150865156 TSecr=475392
885	48.219306742	10.238.221.118	10.238.221.32	SSHv2	1634	Client: Key Exchange Init
886	48.220488446	10.238.221.32	10.238.221.118	TCP	66	22 → 55702 [ACK] Seq=39 Ack=1602 Win=8704 Len=0 TSval=475392 TSecr=150865156
887	48.220488922	10.238.221.32	10.238.221.118	SSHv2	850	Server: Key Exchange Init
888	48.221234826	10.238.221.118	10.238.221.32	TCP	66	55702 → 22 [FIN, ACK] Seq=1602 Ack=823 Win=64512 Len=0 TSval=150865158 TSecr=475392
889	48.221235376	10.238.221.32	10.238.221.118	TCP	66	22 → 55702 [FIN, ACK] Seq=823 Ack=1602 Win=8704 Len=0 TSval=475392 TSecr=150865156
890	48.221375909	10.238.221.118	10.238.221.32	TCP	66	55702 → 22 [ACK] Seq=1603 Ack=824 Win=64512 Len=0 TSval=150865158 TSecr=475392
891	48.222063500	10.238.221.32	10.238.221.118	TCP	66	22 → 55702 [ACK] Seq=824 Ack=1603 Win=8704 Len=0 TSval=475392 TSecr=150865158
892	48.232302425	10.238.221.118	10.238.221.32	TCP	74	55710 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=150865169 TSecr=0 WS=1024
893	48.233872579	10.238.221.32	10.238.221.118	TCP	74	22 → 55710 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=475393 TSecr=150865169 WS=32
894	48.233978134	10.238.221.118	10.238.221.32	TCP	66	55710 → 22 [ACK] Seq=1 Ack=1 Win=64512 Len=0 TSval=150865171 TSecr=475393
895	48.234460061	10.238.221.118	10.238.221.32	SSHv2	99	Client: Protocol (SSH-2.0-OpenSSH_10.2p1 Debian-3)
896	48.235610778	10.238.221.32	10.238.221.118	TCP	66	22 → 55710 [ACK] Seq=1 Ack=34 Win=5792 Len=0 TSval=475394 TSecr=150865171
897	48.239568190	10.238.221.32	10.238.221.118	SSHv2	104	Server: Protocol (SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1)
898	48.239596097	10.238.221.118	10.238.221.32	TCP	66	55710 → 22 [ACK] Seq=34 Ack=39 Win=64512 Len=0 TSval=150865176 TSecr=475394
899	48.240159791	10.238.221.32	10.238.221.118	SSHv2	850	Server: Key Exchange Init
900	48.240174677	10.238.221.118	10.238.221.32	TCP	66	55710 → 22 [ACK] Seq=34 Ack=823 Win=64512 Len=0 TSval=150865177 TSecr=475394
901	48.240811510	10.238.221.118	10.238.221.32	SSHv2	1634	Client: Key Exchange Init
902	48.241714979	10.238.221.32	10.238.221.118	TCP	66	22 → 55710 [ACK] Seq=823 Ack=1602 Win=8704 Len=0 TSval=475394 TSecr=150865178
903	48.242258765	10.238.221.118	10.238.221.32	TCP	66	55710 → 22 [FIN, ACK] Seq=1602 Ack=823 Win=64512 Len=0 TSval=150865179 TSecr=475394
904	48.242643433	10.238.221.32	10.238.221.118	TCP	66	22 → 55710 [FIN, ACK] Seq=823 Ack=1602 Win=8704 Len=0 TSval=475394 TSecr=150865178
905	48.242741136	10.238.221.118	10.238.221.32	TCP	66	55710 → 22 [ACK] Seq=1603 Ack=824 Win=64512 Len=0 TSval=150865180 TSecr=475394
906	48.243907484	10.238.221.32	10.238.221.118	TCP	66	22 → 55710 [ACK] Seq=824 Ack=1603 Win=8704 Len=0 TSval=475394 TSecr=150865179
907	48.263517452	10.238.221.118	10.238.221.32	TCP	74	55722 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=150865191 TSecr=0 WS=1024



- **Uploading logs to kibana :** Uploading authentication logs into Kibana for analysis.



- **Log Analysis :** Kibana Discover showing failed logins



3. Log Management Fundamentals

- Log management is a fundamental component of Security Operations Center (SOC) operations. Logs provide detailed records of activities occurring within systems, applications, servers, network devices, and security tools. SOC analysts use logs to monitor environments, detect suspicious activities, investigate incidents, and support forensic analysis.



- **Log Lifecycle**

- The log lifecycle describes the complete process through which logs move from creation to analysis.

1. **Log Collection**

- Log collection is the process of gathering logs from multiple devices and systems across the organization.
- Fluentd and Logstash is one the log collection tool.
- It Centralize security data, Improve monitoring visibility and Enable faster investigations.

- **Sources of Logs:**

1. Operating systems
2. Firewalls
3. Servers
4. Applications
5. Network devices
6. Endpoints

2. **Log Normalization**

- Different systems generate logs in different formats. Log normalization converts these logs into a standardized structure so they can be analyzed consistently
- E.g. Windows log, Linux logs, Firewall Logs.
- JSON and CEF (Common Event Format) this is some common formats use by SIEM.

3. **Log Storage**

- After collection and normalization, logs are stored in centralized repositories or SIEM platforms.

- **Storage Platforms:**

1. SIEM databases
2. Cloud storage
3. Security data lakes

4. **Log Retention**

- Log retention defines how long logs are stored before deletion or archiving.
- **Factors Affecting Retention:**



1. Organizational policy
2. Compliance requirements
3. Storage capacity

5. Log Analysis

- Log analysis involves examining logs to identify suspicious activities, security incidents, and operational issues.
- Activities include : ☐ Searching logs, Correlating events, Detecting anomalies and Generating alerts.
- E.g. Multiple failed login attempts followed by a successful login may indicate a brute-force attack.

- **Common Log Types**

- SOC analysts work with various log types during security monitoring and investigations.

1. Windows Event Logs

- Windows systems generate Event Logs that record operating system and security activities.
- E.g. event id 4624 – successful login, event id 4625 – failed login, etc.

- Main Categories:

1. Security Logs
2. System Logs
3. Application Logs

2. Syslog

- Syslog is a standard logging protocol commonly used in Linux systems and network devices.
- Syslog provides centralized logging across infrastructure devices.

- Devices Using Syslog:

1. Linux servers
2. Routers
3. Switches
4. Firewalls



3. HTTP Server Logs

- HTTP server logs record requests made to web servers such as Apache and Nginx.
- It contain info about Client ip address, Request method (GET/POST), Requested URL, Response status code.
- Used to detect web attacks, Identify suspicious activity, Monitor user activity.

• Log normalization

- Log normalization is the process of converting logs generated from different devices, operating systems, applications, and security tools into a common standardized format. In a SOC environment, logs are collected from multiple sources, and each source may generate logs in completely different structures and formats. Normalization helps SOC analysts analyze and correlate these logs efficiently.

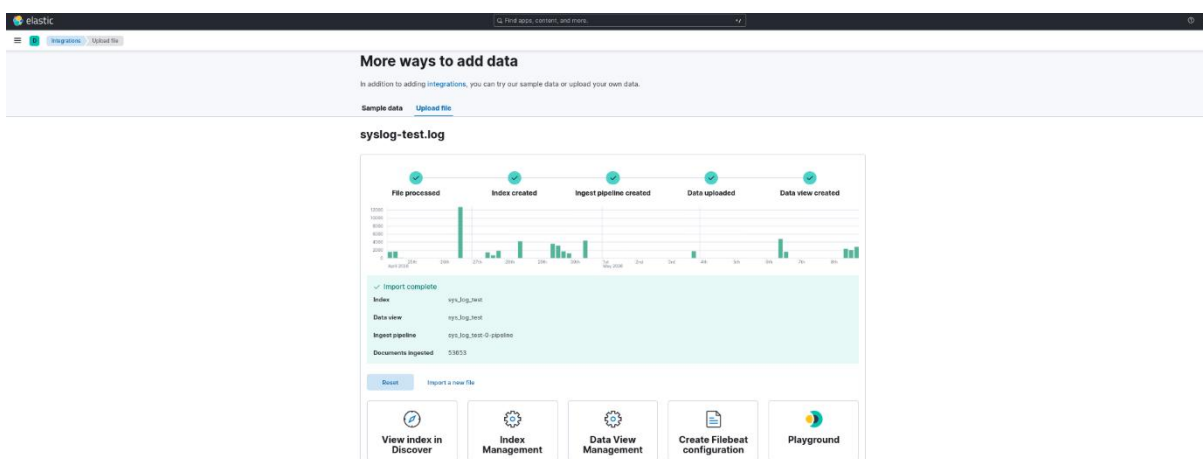
• Log collection pipeline

• Creating a logger message

```
(root@kali) ~/home/kali
# logger "SOC ALERT TEST - Unauthorized SSH attempt detected"
logger "Failed login attempt from 192.168.1.50"
logger "Potential brute force activity detected"

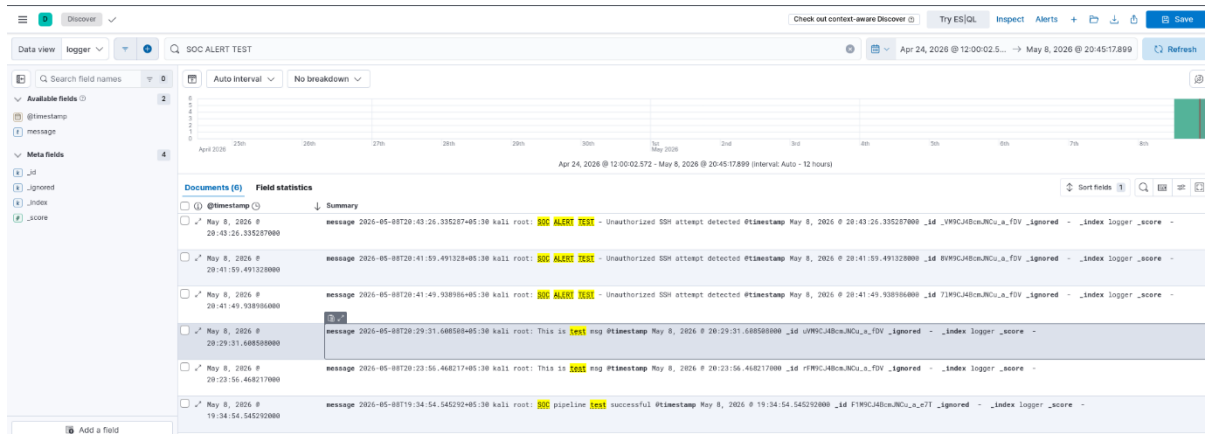
(root@kali) ~/home/kali
# sudo tail -n 4 /var/log/syslog
2026-05-08T20:43:17.844676+05:30 kali filebeat[811]: {"log.level":"info","@timestamp":"2026-05-08T20:43:17.842+0530","log.logger":"monitoring","log.origin":{"function":"github.com/elastic/beats/v7/libbeat/monitoring/report/log.(*reporter).logSnapshot","file.name":"log/log.go","file.line":192},"message":"Non-zero metrics in the last 30s","service.name":"filebeat","monitoring":{"metrics":{"beat":{"cgroup":{"memory":{"mem":{"usage":{"bytes":74977280}}},"cpu":{"system":{"ticks":14860,"time":{"ms":10}}},"total":{"ticks":19090,"time":{"ms":10},"value":19090},"user":{"ticks":4230}}},"handles":{"limit":{"hard":524288,"soft":524287},"open":9},"info":{"ephemeral_id":"95092f47-47cb-4ed0-a16b-055c21126e8c"},"uptime":{"ms":7800930},"version":"8.19.14"},"memstats":{"gc_next":18043290,"memory_alloc":8901128,"memory_total":61993096,"rss":31637504},"runtime":{"goroutines":29}},"filebeat":{"events":{"active":0},"harvester":{"open_files":0,"running":0},"libbeat":{"config":{"module":{"running":0},"output":{"events":{"active":0},"write":{"latency":{"histogram":{"count":0,"max":0,"mean":0,"median":0,"min":0,"p75":0,"p95":0,"p99":0,"stddev":0}}},"pipeline":{"clients":0,"events":{"active":0},"queue":{"filled":{"bytes":0,"events":0,"pct":0},"max_bytes":0,"max_events":3200}}},"registrar":{"states":{"current":0},"system":{"load":{"1":1.37,"5":1.32,"15":1.19,"norm":{"1":0.3425,"5":0.33,"15":0.2975}}},"ecs.version":"1.6.0"}}}}
2026-05-08T20:43:26.335287+05:30 kali root: SOC ALERT TEST - Unauthorized SSH attempt detected
2026-05-08T20:43:26.348533+05:30 kali root: Failed login attempt from 192.168.1.50
2026-05-08T20:43:26.357242+05:30 kali root: Potential brute force activity detected
```

• Uploading logs to SIEM (Elasticsearch)





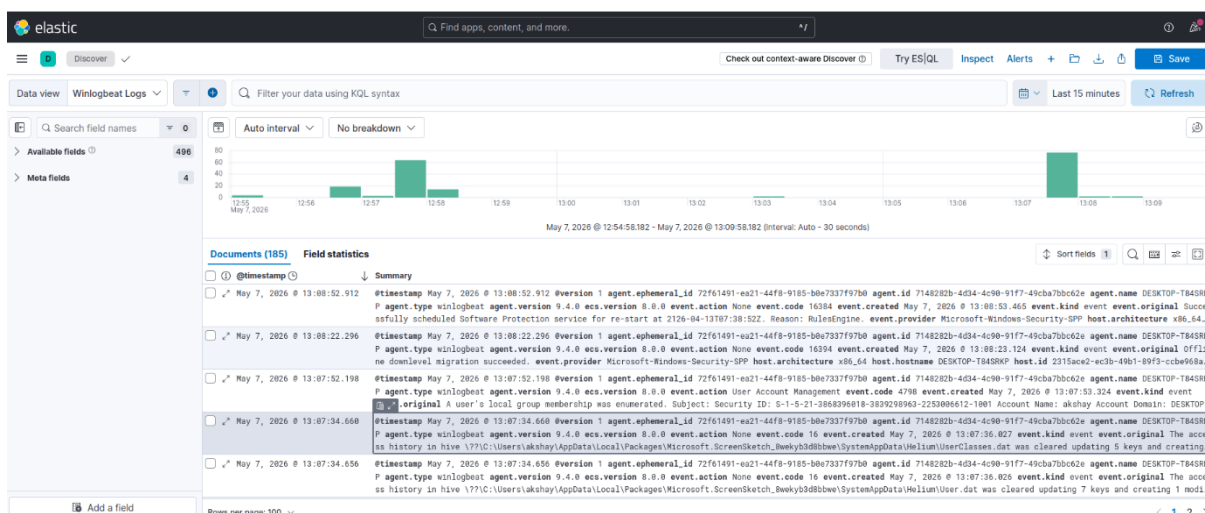
- **Logger msg result in kibana**



- **KQL Query Practice:**

- The objective of this lab is to build a basic Security Operations Center (SOC) monitoring pipeline using the Elastic Stack. The lab demonstrates how logs are collected from a Windows machine, forwarded through Logstash, stored in Elasticsearch, and analyzed in Kibana for security monitoring purposes.
- Elasticsearch acts as the central storage engine for all collected logs. It indexes logs so that security analysts can search and analyze events quickly.
- Installed Kibana on Ubuntu and connected it to Elasticsearch.

- **Kibana dashboard**





- Kibana provides a graphical interface for viewing and analyzing logs stored in Elasticsearch.
- Installed Logstash on Ubuntu and configured it to receive logs from Winlogbeat.
- **/etc/logstash/conf.d/winlogbeat.conf**

```
input {
  beats {
    port => 5044
  }
}

filter {
  mutate {
    add_field => { "lab" => "SOC_Lab" }
  }
}

output {
  elasticsearch {
    hosts => ["http://localhost:9200"]
    index => "winlogbeat-logs"
  }
}
```

- Logstash acts as the processing layer in the SOC pipeline.
- Installed Winlogbeat on Windows to collect Windows Security Event Logs.

- **winlogbeat.yml**

```
winlogbeat.event_logs:
  - name: Security

output.logstash:
  hosts: ["10.238.221.226:5044"]
```

- Winlogbeat collects Windows Event Logs and securely forwards them to Logstash.
- Winlogbeat automatically normalized raw Windows Event Logs into Elastic Common Schema (ECS) formatted JSON events before indexing into Elasticsearch. This enabled structured querying in Kibana using fields such as event.code and winlog.event_id.



- Generated failed login attempts on Windows by entering incorrect passwords.

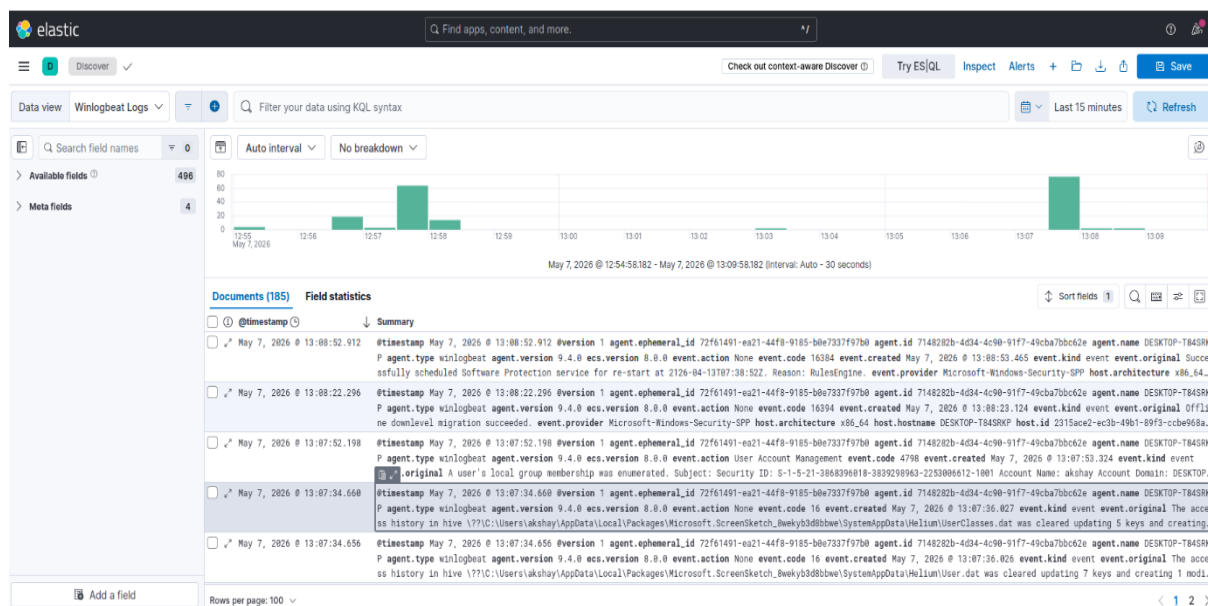
```
Microsoft Windows [Version 10.0.26200.8246]
(c) Microsoft Corporation. All rights reserved.

C:\Users\akshay>runas /user:Administrator cmd
Enter the password for Administrator:
Attempting to start cmd as user "DESKTOP-T84SRKP\Administrator" ...
RUNAS ERROR: Unable to run - cmd
1326: The user name or password is incorrect.

C:\Users\akshay>runas /user:Administrator cmd
Enter the password for Administrator:
Attempting to start cmd as user "DESKTOP-T84SRKP\Administrator" ...
RUNAS ERROR: Unable to run - cmd
1326: The user name or password is incorrect.

C:\Users\akshay>
```

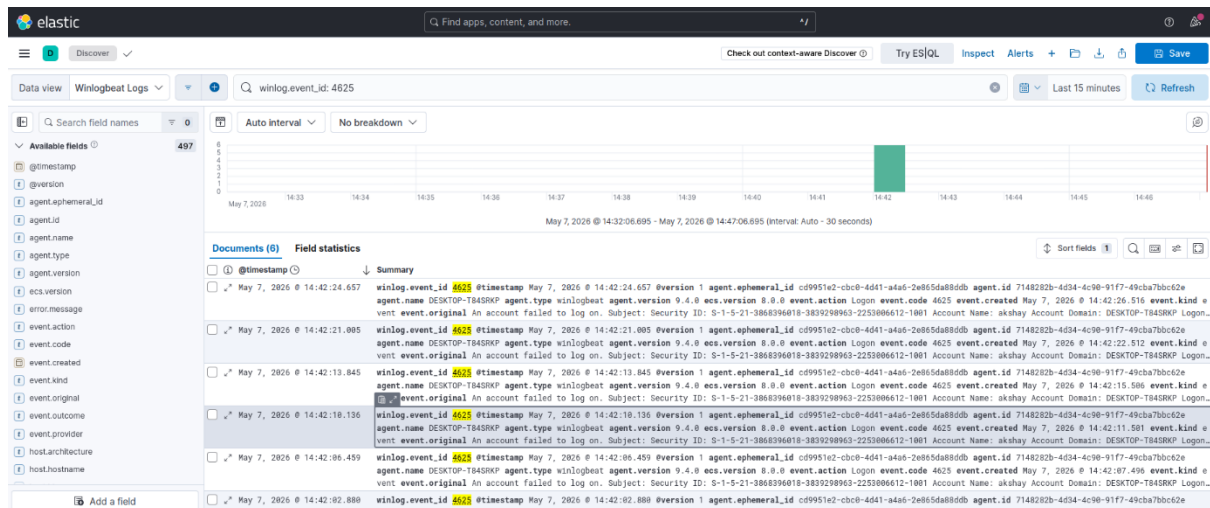
- Kibana dashboard





- **Event ID 4625 Detection**

- Windows Security Auditing was configured to log failed authentication attempts by enabling “Audit logon events” and “Audit account logon events” for Success and Failure. Failed login attempts generated Event ID 4625, which was collected by Winlogbeat and visualized in Kibana.



- Logstash converted incoming logs into structured JSON documents before storing them in Elasticsearch.

```
root@ak-VirtualBox:/home/ak
root@ak-VirtualBox:/media/sf_apachelogs
root@ak-VirtualBox:/home/ak
{"host":{"name":"ak-VirtualBox"},"log":{"file":{"path":"/media/sf_apachelogs/access.log"},"timestamp":"19/Oct/2025:14:06:46 +0530","event":{"original":":1 - [19/Oct/2025:14:06:46 +0530] \"/GET /dashboard/ HTTP/1.1\" 200 5187 \"-\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\" \"\" \"@version\":\"1\", \"source\":{\"address\":\"::1\"}, \"user_agent\":{\"original\":\"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\"}, \"@timestamp\":\"2026-05-07T11:21:34.807759294Z\", \"http\":{\"response\":{\"body\":{\"bytes\":5187}, \"status_code\":200}, \"version\":\"1.1\", \"request\":{\"method\":\"GET\"}, \"message\":\"::1 - [19/Oct/2025:14:06:46 +0530] \"/GET /dashboard/ HTTP/1.1\" 200 5187 \"-\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\" \"\" \"url\":{\"original\":\"/dashboard/\"}}}}}}
{"host":{"name":"ak-VirtualBox"},"log":{"file":{"path":"/media/sf_apachelogs/access.log"},"timestamp":"19/Oct/2025:14:06:47 +0530","event":{"original":":1 - [19/Oct/2025:14:06:47 +0530] \"/GET /dashboard/images/favicon.png HTTP/1.1\" 200 2588 \"http://localhost/dashboard/\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\" \"\" \"@version\":\"1\", \"source\":{\"address\":\"::1\"}, \"user_agent\":{\"original\":\"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\"}, \"@timestamp\":\"2026-05-07T11:21:34.825782084Z\", \"http\":{\"response\":{\"body\":{\"bytes\":2588}, \"status_code\":200}, \"version\":\"1.1\", \"request\":{\"method\":\"GET\", \"referrer\":\"http://localhost/dashboard/\"}, \"message\":\"::1 - [19/Oct/2025:14:06:47 +0530] \"/GET /dashboard/images/favicon.png HTTP/1.1\" 200 2588 \"http://localhost/dashboard/\" \"\" \"url\":{\"original\":\"/dashboard/images/favicon.png\"}}}}}}
{"host":{"name":"ak-VirtualBox"},"log":{"file":{"path":"/media/sf_apachelogs/access.log"},"timestamp":"19/Oct/2025:14:07:59 +0530","event":{"original":":1 - [19/Oct/2025:14:07:59 +0530] \"/GET /Online%20mobile%20cover%20shop%20system%202.0/css/styles.css HTTP/1.1\" 200 244395 \"http://localhost/Online%20mobile%20cover%20shop%20system%202.0/custlogin.php\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\" \"\" \"@version\":\"1\", \"source\":{\"address\":\"::1\"}, \"user_agent\":{\"original\":\"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\"}, \"@timestamp\":\"2026-05-07T11:21:34.832620745Z\", \"http\":{\"response\":{\"body\":{\"bytes\":244395}, \"status_code\":200}, \"version\":\"1.1\", \"request\":{\"method\":\"GET\", \"referrer\":\"http://localhost/Online%20mobile%20cover%20shop%20system%202.0/custlogin.php\"}, \"message\":\"::1 - [19/Oct/2025:14:07:59 +0530] \"/GET /Online%20mobile%20cover%20shop%20system%202.0/css/styles.css HTTP/1.1\" 200 244395 \"http://localhost/Online%20mobile%20cover%20shop%20system%202.0/custlogin.php\" \"\" \"url\":{\"original\":\"/Online%20mobile%20cover%20shop%20system%202.0/css/styles.css\"}}}}}}
{"host":{"name":"ak-VirtualBox"},"log":{"file":{"path":"/media/sf_apachelogs/access.log"},"timestamp":"19/Oct/2025:14:09:11 +0530","event":{"original":":1 - [19/Oct/2025:14:09:11 +0530] \"/GET /upload HTTP/1.1\" 301 331 \"-\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\" \"\" \"@version\":\"1\", \"source\":{\"address\":\"::1\"}, \"user_agent\":{\"original\":\"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\"}, \"@timestamp\":\"2026-05-07T11:21:34.842787740Z\", \"http\":{\"response\":{\"body\":{\"bytes\":331}, \"status_code\":301}, \"version\":\"1.1\", \"request\":{\"method\":\"GET\"}, \"message\":\"::1 - [19/Oct/2025:14:09:11 +0530] \"/GET /upload HTTP/1.1\" 301 331 \"-\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\" \"\" \"url\":{\"original\":\"/upload\"}}}}}}
```



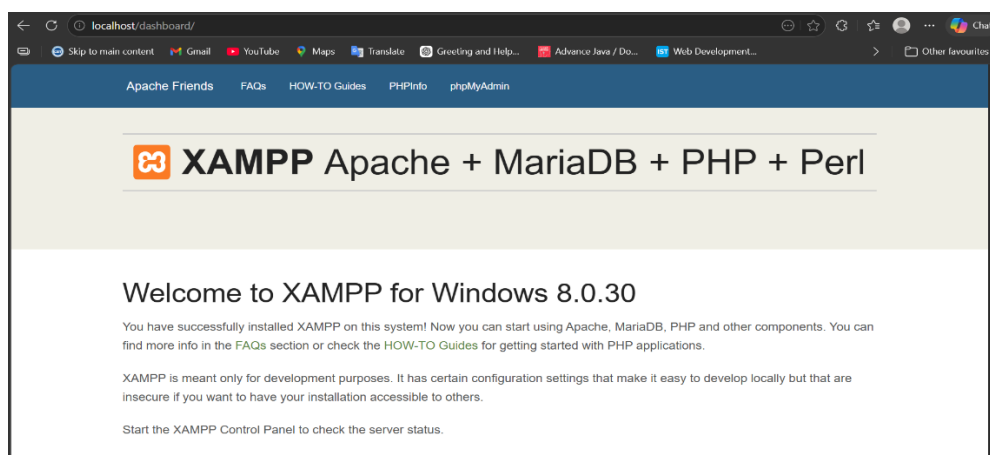

- **Log collection pipeline summary**

- A centralized log management pipeline was implemented using Winlogbeat, Logstash, Elasticsearch, and Kibana. Windows Security Event Logs were collected from a Windows 11 system and forwarded to Logstash for processing. The logs were normalized into Elastic Common Schema (ECS) JSON format and indexed into Elasticsearch. Kibana was used to visualize and query security events. Failed authentication attempts (Event ID 4625) were successfully detected and analyzed, demonstrating a functional SOC monitoring workflow.

- **converting an Apache access log to JSON**

component used :

- Ubuntu VM
 - XAMPP Apache Server
 - Apache access.log
 - Logstash
 - Elasticsearch
 - Kibana
-
- Logstash continuously monitored Apache access logs.
 - Using Logstash extracted fields such as source ip , http methods,etc.
 - The extracted fields were converted into structured JSON.
-
- **Apache dashboard**





- **sudo nano /etc/logstash/conf.d/apache.conf**
 - Creating Logstash Apache Pipeline

```
GNU nano 6.2 /etc/logstash/conf.d/apache.conf
input {
  file {
    path => "/media/sf_apachelogs/access.log"
    start_position => "beginning"
    sincedb_path => "/dev/null"
  }
}

filter {
  grok {
    match => {
      "message" => "%{COMBINEDAPACHELOG}"
    }
  }
}

output {
  file {
    path => "/home/ak/apache_normalized.json"
    codec => json_lines
  }

  stdout {
    codec => rubydebug
  }
}
```

- **access.log (apache log created)**

```
root@ak-VirtualBox:/home/ak# ll /media/sf_apachelogs
total 121
drwxrwx--- 1 root vboxsf 4096 May  7 16:43 ./
drwxr-xr-x 5 root root   4096 May  7 16:44 ../
-rwxrwx--- 1 root vboxsf 93977 May  7 16:52 access.log*
-rwxrwx--- 1 root vboxsf 12777 May  7 16:43 error.log*
-rwxrwx--- 1 root vboxsf    7 May  7 16:43 httpd.pid*
-rwxrwx--- 1 root vboxsf 3146 Oct 18 2023 install.log*
-rwxrwx--- 1 root vboxsf    0 Oct 18 2025 ssl_request.log*
root@ak-VirtualBox:/home/ak#
```



- **cat /home/ak/apache_normalized.json(to verify JSON output)**

```
root@ak-VirtualBox:/home/ak# cat /home/ak/apache_normalized.json
{"host":{"name":"ak-VirtualBox"},"log":{"file":{"path":"/media/sf_apachelogs/access.log"},"timestamp":"19/Oct/2025:14:06:46 +0530","event":{"original":"::1 - - [19/Oct/2025:14:06:46 +0530] \"GET /dashboard/ HTTP/1.1\" 200 5187 \"-\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\""},@version\":\"1\",\"source\":{\"address\":\"::1\"},\"user_agent\":{\"original\":\"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\"},\"@timestamp\":\"2026-05-07T11:21:34.807759294Z\", \"http\":{\"response\":{\"body\":{\"bytes\":5187},\"status_code\":200},\"version\":\"1.1\", \"request\":{\"method\":\"GET\"}},\"message\":\"::1 - - [19/Oct/2025:14:06:46 +0530] \"GET /dashboard/ HTTP/1.1\" 200 5187 \"-\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\"\"},\"url\":{\"original\":\"/dashboard/\"}}
{"host":{"name":"ak-VirtualBox"},"log":{"file":{"path":"/media/sf_apachelogs/access.log"},"timestamp":"19/Oct/2025:14:06:47 +0530","event":{"original":"::1 - - [19/Oct/2025:14:06:47 +0530] \"GET /dashboard/images/favicon.png HTTP/1.1\" 200 2508 \"http://localhost/dashboard/\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\"},\"@timestamp\":\"2026-05-07T11:21:34.825782004Z\", \"http\":{\"response\":{\"body\":{\"bytes\":2508},\"status_code\":200},\"version\":\"1.1\", \"request\":{\"method\":\"GET\", \"referrer\":\"http://localhost/dashboard/\"}},\"message\":\"::1 - - [19/Oct/2025:14:06:47 +0530] \"GET /dashboard/images/favicon.png HTTP/1.1\" 200 2508 \"http://localhost/dashboard/\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\"\"},\"url\":{\"original\":\"/dashboard/images/favicon.png\"}}
{"host":{"name":"ak-VirtualBox"},"log":{"file":{"path":"/media/sf_apachelogs/access.log"},"timestamp":"19/Oct/2025:14:07:59 +0530","event":{"original":"::1 - - [19/Oct/2025:14:07:59 +0530] \"GET /Online%20mobile%20cover%20shop%20system%202.0/css/styles.css HTTP/1.1\" 200 244395 \"http://localhost/Online%20mobile%20cover%20shop%20system%202.0/custlogin.php\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\"},\"@timestamp\":\"2026-05-07T11:21:34.832620745Z\", \"http\":{\"response\":{\"body\":{\"bytes\":244395},\"status_code\":200},\"version\":\"1.1\", \"request\":{\"method\":\"GET\", \"referrer\":\"http://localhost/Online%20mobile%20cover%20shop%20system%202.0/custlogin.php\"}},\"message\":\"::1 - - [19/Oct/2025:14:07:59 +0530] \"GET /Online%20mobile%20cover%20shop%20system%202.0/css/styles.css HTTP/1.1\" 200 244395 \"http://localhost/Online%20mobile%20cover%20shop%20system%202.0/custlogin.php\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\"\"},\"url\":{\"original\":\"/Online%20mobile%20cover%20shop%20system%202.0/css/styles.css\"}}
{"host":{"name":"ak-VirtualBox"},"log":{"file":{"path":"/media/sf_apachelogs/access.log"},"timestamp":"19/Oct/2025:14:09:11 +0530","event":{"original":"::1 - - [19/Oct/2025:14:09:11 +0530] \"GET /upload HTTP/1.1\" 301 331 \"-\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\"},\"@timestamp\":\"2026-05-07T11:21:34.842787740Z\", \"http\":{\"response\":{\"body\":{\"bytes\":331},\"status_code\":301},\"version\":\"1.1\", \"request\":{\"method\":\"GET\"}},\"message\":\"::1 - - [19/Oct/2025:14:09:11 +0530] \"GET /upload HTTP/1.1\" 301 331 \"-\" \"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 Edg/141.0.0.0\"\"},\"url\":{\"original\":\"/upload\"}}
```

- In this exercise, Apache access logs generated from the XAMPP web server were successfully normalized using Logstash on Ubuntu. Raw logs from the Apache access.log file were collected and parsed using Grok filters to extract important fields such as source IP address, HTTP request method, URL, response status code, timestamp, and user-agent information. These unstructured log entries were then converted into structured JSON format, making them easier to search, analyze, and visualize in Elasticsearch and Kibana. The normalization process demonstrated a real-world SOC workflow involving log collection, parsing, storage, and analysis. Test web requests to the Apache dashboard confirmed that Logstash was successfully processing and displaying normalized events, enabling efficient monitoring and threat analysis.

4. Security Tools Overview

- In a Security Operations Center (SOC), security tools are the backbone of threat detection, monitoring, and incident response. These tools collect data from endpoints, networks, and applications, analyze it, and help analysts identify malicious activity in real time.

• Key Tools in SOC :

1. SIEM (Security Information and Event Management)

- A SIEM collects, stores, normalizes, and analyzes logs from multiple sources to detect security threats.



- It Collects logs from servers, firewalls, endpoints.
- It Correlates events across systems
- It Detects anomalies and attacks.
- Generates real-time alerts.
- E.g. Splunk , IBM QRadar.

2. EDR (Endpoint Detection and Response)

- EDR tools monitor and respond to threats on endpoints like laptops, desktops, and servers.
- Monitors processes and file activity
- Detects malware behavior
- Blocks suspicious execution
- Provides endpoint investigation tools
- E.g. CrowdStrike Falcon.

3. IDS/IPS (Intrusion Detection and Prevention System)

- IDS/IPS tools monitor network traffic for malicious activity.
- Ids detects attacks and alert.
- Ips detect and block alerts.
- Monitors network packets
- Detects known attack patterns
- Blocks malicious traffic (IPS mode)
- Uses rule-based detection

4. Vulnerability Scanners

- Vulnerability scanners identify security weaknesses in systems, applications, and networks.
- Scans systems for known vulnerabilities
- Maps vulnerabilities to CVEs
- Assigns severity (CVSS score)
- Generates security reports

- **Snort Rule Testing**

- **Command used**

1.sudo apt install snort -y

- To Install Snort software

2. sudo nano /etc/snort/rules/local.rules

- To add rule in file in local.rules



3. sudo snort -A console -q -c /etc/snort/snort.conf -i eth0

- to open snort in ids mode

- adding rule in file

```
GNU nano 8.7 /etc/snort/rules/local.rules *
# $Id: local.rules,v 1.11 2004/07/23 20:15:44 bmc Exp $
#
# LOCAL RULES
#
# This file intentionally does not come with signatures.  Put your local
# additions here.
alert tcp any any -> any 80 (msg:"Malicious Host Detected"; content:"malicious.com"; sid:1000010; rev:1;)
```

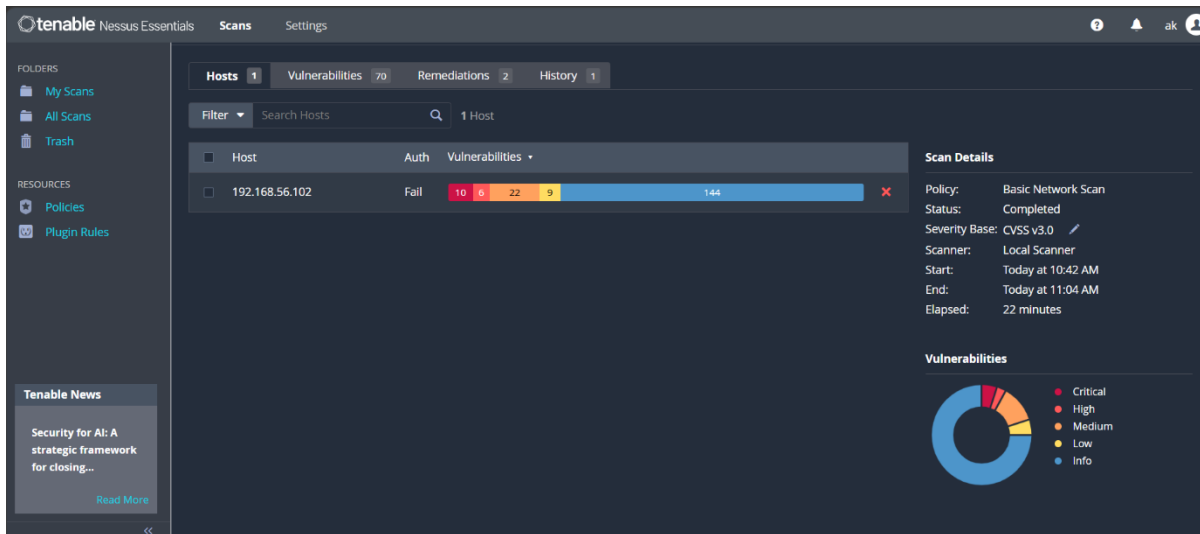
- Performing Nessus Scan

- Scan info:

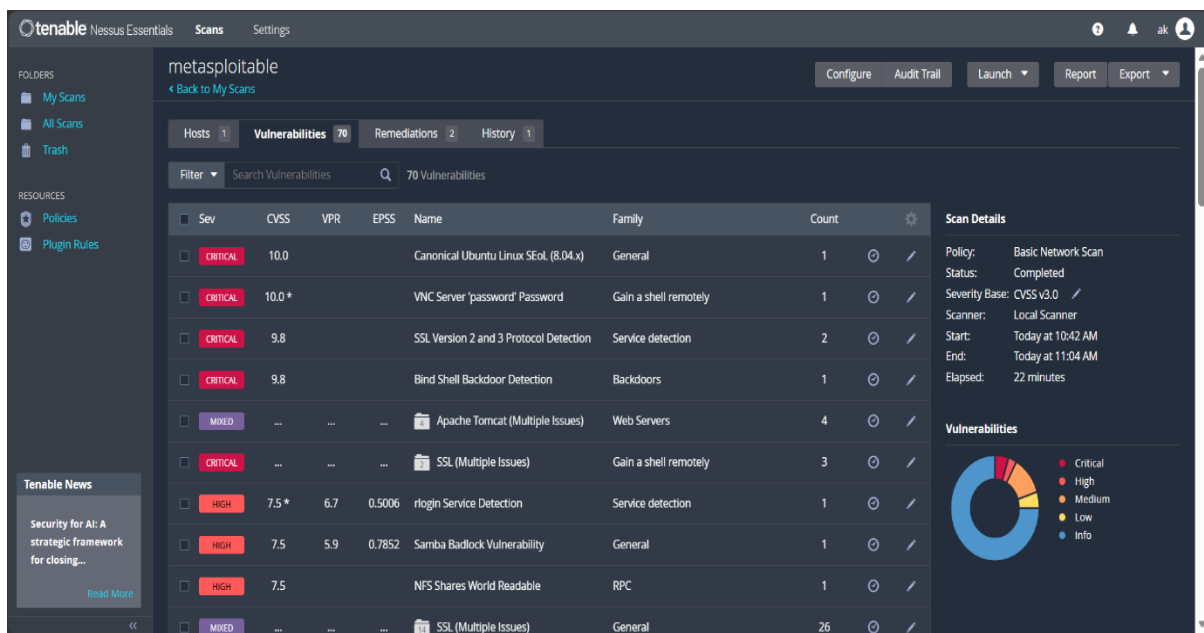
- **Target IP:** 192.168.56.102
- **Hostname:** metasploitable2 Operating System: Linux (Ubuntu-based)
- **Scan Tool:** Tenable Nessus



- **Nessus scan result**



- **Vulnerability found**





- Top 3 vulnerabilities

1. Canonical Ubuntu Linux .

CRITICAL

Canonical Ubuntu Linux SEoL (8.04.x)

< >

Plugin Details

Description

According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

Solution

Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

See Also

<http://www.nessus.org/u73bdb2d2e>

Output

OS : Ubuntu Linux 8.04
Security End of Life : May 8, 2013
Time since Security End of Life (Est.) : >= 13 years

To see debug logs, please visit individual host

Port

Hosts

80 / tcp / www 192.168.56.102

Severity: Critical
ID: 201352
Version: 1.2
Type: combined
Family: General
Published: July 3, 2024
Modified: March 26, 2025

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 10.0
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information

CPE: cpe:/o:canonical:ubuntu_linux
Unsupported by vendor: true

2. Vnc server

metasploitable / Plugin #61708

Configure Audit Trail Launch Report Export

Back to Vulnerabilities

Hosts 1 Vulnerabilities 6 Remediations 2 History 1

CRITICAL

VNC Server 'password' Password

< >

Plugin Details

Description

The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution

Secure the VNC service with a strong password.

Output

Nessus logged in using a password of "password".

To see debug logs, please visit individual host

Port

Hosts

5900 / tcp / vnc 192.168.56.102

Severity: Critical
ID: 61708
Version: \$Revision: 1.2 \$
Type: remote
Family: Gain a shell remotely
Published: August 29, 2012
Modified: September 24, 2015

Risk Information

Risk Factor: Critical
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information

Default Account: true
Exploited by Nessus: true



3. Ssl version 2 and 3 protocol detection

metasploitable / Plugin #20007

[Configure](#) [Audit Trail](#) [Launch](#) [Report](#) [Export](#)

[Hosts](#) 1 [Vulnerabilities](#) 6 [Remediations](#) 2 [History](#) 1

CRITICAL SSL Version 2 and 3 Protocol Detection

Description

The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including:

- An insecure padding scheme with CBC ciphers.
- Insecure session renegotiation and resumption schemes.

An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.

Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely.

NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of 'strong cryptography'.

Solution

Consult the application's documentation to disable SSL 2.0 and 3.0.
Use TLS 1.2 (with approved cipher suites) or higher instead.

Plugin Details

Severity: Critical
ID: 20007
Version: 1.35
Type: remote
Family: Service detection
Published: October 12, 2005
Modified: April 13, 2026

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 9.8
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information

- **Performing OSquery monitoring**

- Osquery is an endpoint monitoring tool used in SOC environments to gain visibility into system-level activities using SQL-like queries. In this practical, Osquery was installed on a Windows VM and used to monitor running processes using the query `SELECT * FROM processes;`. A harmless batch file was executed to simulate a malicious process, which was successfully detected through process listing queries. This demonstrates how SOC analysts use Osquery for endpoint monitoring, threat detection, and incident investigation in real-world environments.

Steps used

1. Downloaded osquery from official Osquery release page
2. Installed osquery Keeping default settings
3. Used this query to view all running processes - `SELECT * FROM processes;`



- all running processes by osquery

```
osquery> SELECT pid,name,path FROM processes WHERE name='cmd.exe';
osquery> SELECT * FROM processes;
```

pid	name	path	cmdline
0	[System Process]		
4	System		
100	Secure System		

- Create harmless bat file named - malicious.bat
- code contained

```
@echo off
echo Simulating suspicious process...
timeout 60
```

- run this malicious.bat .
- and then again run the osquery to detect the file

name	pid	start_time	path
FileCoAuth.exe	888	1778309244	C:\Program Files\Microsoft OneDrive\26.063.0405.0002\FileCoAuth.exe
OpenConsole.exe	13648	1778309233	C:\Program Files\WindowsApps\Microsoft.WindowsTerminal_1.24.10921.0_x64__8wekyb3d8bbwe\OpenConsole.exe
cmd.exe	22268	1778309232	C:\Windows\System32\cmd.exe
conhost.exe	10024	1778309232	C:\Windows\System32\conhost.exe
msedge.exe	1784	1778309229	C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
msedge.exe	12440	1778309229	C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
smartscreen.exe	19208	1778309151	C:\Windows\System32\smartscreen.exe
msedge.exe	9768	1778308935	C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
msedge.exe	18052	1778308600	C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
Notepad.exe	18616	1778307868	C:\Program Files\WindowsApps\Microsoft.WindowsNotepad_11.2512.29.0_x64__8wekyb3d8bbwe\Notepad\Notepad.exe
osqueryi.exe	9816	1778307581	C:\Program Files\osquery\osqueryi.exe



5. Basic Security Concepts

- In cybersecurity and SOC (Security Operations Center) work, basic security concepts form the foundation for understanding how attacks happen and how defenses are built. These concepts are used daily in incident detection, risk analysis, and threat investigation.
- **CIA Triad**
 - The CIA Triad is the core principle of information security. It defines the three main goals of protecting any system or data.
 1. **Confidentiality**
 - Confidentiality ensures that sensitive information is only accessible to authorized users and is protected from unauthorized access. It is one of the most critical aspects of information security because data leaks can lead to financial loss, privacy violations, and reputational damage.
 - If confidentiality is broken, attackers may steal sensitive data through methods such as phishing attacks, password cracking, or database breaches.
 2. **Integrity**
 - Integrity ensures that data remains accurate, consistent, and unaltered during storage, processing, or transmission. It guarantees that information has not been modified by unauthorized users or malicious programs.
 - integrity can be compromised through attacks such as SQL injection, malware modification of files, or unauthorized changes in system logs. Hashing algorithms and digital signatures are commonly used to maintain data integrity.
 3. **Availability**
 - Availability ensures that systems, applications, and data are accessible to authorized users whenever they are needed. It is essential for business continuity and operational efficiency.
 - Availability can be disrupted by attacks such as Distributed Denial of Service (DDoS), ransomware attacks, hardware failures, or system crashes. Organizations use redundancy, backups, and load balancing to maintain high availability.
- **Threat vs Vulnerability vs Risk**
 - Understanding the difference between threat, vulnerability, and risk is essential for analyzing cybersecurity incidents in SOC environments.



1. Threat

- A threat refers to any potential cause of harm to a system or organization. It can be a person, a software program, or an event that has the capability to exploit a system.

2. Vulnerability

- A vulnerability is a weakness or flaw in a system that can be exploited by a threat. Vulnerabilities exist due to poor configuration, outdated software, weak passwords, or unpatched systems.

3. Risk

- Risk is the possibility of loss or damage when a threat exploits a vulnerability. It combines the likelihood of an attack with the potential impact on the organization.
- $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$

- **Defense-in-Depth**

- Defense-in-depth is a cybersecurity strategy that uses multiple layers of security controls to protect systems. Instead of relying on a single security measure, organizations implement several layers of defense so that if one layer fails, others still provide protection.
- These layers may include firewalls, antivirus software, endpoint detection systems, network segmentation, encryption, and security monitoring tools.

- **Zero Trust Security Model**

- The Zero Trust model is a modern cybersecurity approach that assumes no user or system should be trusted by default, even if they are inside the organization's network.
- Instead, every access request must be continuously verified before granting permissions. This includes authentication, authorization, and strict access control.
- In a Zero Trust environment, employees must verify their identity every time they access sensitive systems, and access is granted only to the resources required for their job role. Even internal network traffic is monitored and validated.
- The key idea behind Zero Trust is: "Never trust, always verify." This model significantly reduces the risk of internal and external attacks.



6. Security Operations Workflow

- The Security Operations Workflow defines the step-by-step process followed by SOC (Security Operations Center) teams to detect, analyze, and respond to cybersecurity incidents. It ensures that security alerts are handled in a structured and efficient manner, reducing response time and minimizing damage caused by cyberattacks.
- This workflow is used daily by SOC analysts to handle real-world security incidents such as phishing attacks, malware infections, unauthorized access, and data breaches.
- **stages**
 - 1. Detection Phase**
 - Detection is the first stage of the SOC workflow where potential security incidents are identified. Alerts are generated by security tools such as SIEM and EDR systems when unusual or suspicious activity is detected.
 - Security Information and Event Management (SIEM) tools collect and analyze logs from multiple systems to detect anomalies, while Endpoint Detection and Response (EDR) tools monitor endpoint behavior for malicious activity.
 - 2. Triage Phase**
 - Triage is the process of evaluating and prioritizing alerts based on their severity and potential impact. Since SOC environments generate thousands of alerts daily, it is not possible to investigate every alert immediately.
 - During triage, analysts determine whether an alert is high, medium, or low priority. High-priority alerts are those that indicate active attacks or critical system compromise, while low-priority alerts may represent false positives or harmless activity.
 - 3. Investigation Phase**
 - Investigation is the most detailed phase of the SOC workflow. In this stage, analysts gather and analyze all available information to confirm whether the alert is a real security incident.
 - SOC analysts correlate logs from different sources such as firewalls, endpoints, and servers to understand the full scope of the incident. They also perform IOC (Indicator of Compromise) hunting to identify malicious IPs, domains, file hashes, or suspicious processes.
 - 4. Response Phase**



- The response phase involves taking action to stop the attack and prevent further damage. It is divided into three main steps: containment, eradication, and recovery.

- **Workflow simulation**

- **phishing**

- A phishing attack is a cyberattack where attackers trick individuals into revealing sensitive information or performing actions that benefit the attacker.

Step 1: Phishing Email Reported / Detected

- A suspicious email is identified either through user reporting or automatically detected by security tools such as SIEM or email security gateways. The email is flagged for potential phishing activity based on indicators like unknown sender, suspicious links, or malicious attachments.

Step 2: Create Case in TheHive

- A new incident case is created in TheHive.
This case acts as a central workspace where all investigation activities are tracked, documented, and managed by SOC analysts.

Step 3: Collect Evidence

- The SOC analyst gathers all relevant information related to the phishing email for investigation purposes.

Step 4: Analyze Indicators of Compromise (IOC)

- All collected artifacts are analyzed to identify Indicators of Compromise (IOCs).

Step 5: Decision Point

- After analysis, the incident is classified. – is this Malicious or Not.

Step 6: Contain Incident

- If the email is confirmed malicious, containment actions are performed to prevent further damage.

Step 7: Document Findings

- All investigation details are documented inside TheHive.
 - Proper documentation is essential for auditing, reporting, and future reference.

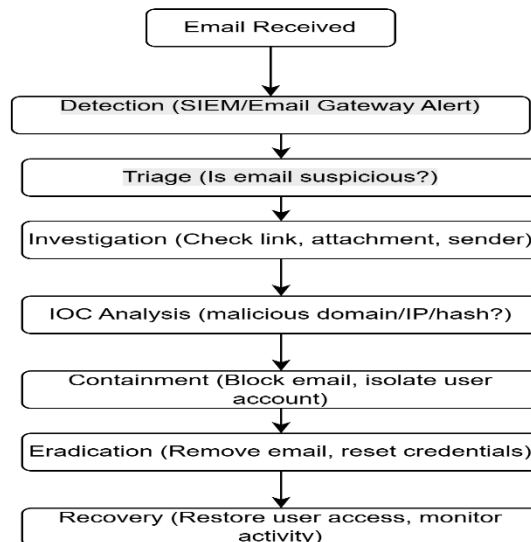
Step 8: Close Case

- Once all response actions are completed and the system is verified as secure, the incident case is formally closed in TheHive. The closure confirms that the



phishing threat has been fully handled and no further malicious activity is detected.

- **flowchart for a phishing email incident**



7. Incident Response Basics

- Incident Response (IR) is a structured approach used by Security Operations Center (SOC) teams to handle cybersecurity incidents effectively. The goal of incident response is to minimize damage, reduce recovery time, and prevent similar incidents in the future.
- A well-defined incident response process ensures that organizations can quickly detect, contain, and recover from attacks such as malware infections, ransomware, phishing, and data breaches.

1. Incident Response Lifecycle

- **Preparation**

- Preparation is the first and most important phase of incident response. It involves building the capability to respond to security incidents before they occur.
- Without preparation, incident response becomes slow and ineffective during real attacks.



- **Identification**
 - Identification is the process of detecting and confirming whether a security incident has occurred.
- **Containment**
 - Containment is the process of stopping the attack from spreading further within the system or network.
- **Eradication**
 - Eradication involves completely removing the root cause of the incident from the environment.
- **Recovery**
 - Recovery focuses on restoring systems and services back to normal operation safely.
- **Lessons Learned**
 - The final phase is one of the most important for improving future security posture.

2. NIST SP 800-61 Framework

- The most widely used incident response guideline is NIST SP 800-61.
- This framework provides best practices for detecting, responding to, and recovering from cybersecurity incidents.
- This framework provides structured guidance on:
 - How to prepare for incidents
 - How to detect and analyze incidents
 - How to contain and recover from attacks
 - How to improve security after incidents
 -

8. Documentation Standards in SOC

- Documentation standards in a Security Operations Center (SOC) define how security incidents, response actions, and operational procedures are recorded in a structured and consistent manner. Proper documentation ensures that every security event is traceable, auditable, and useful for future analysis. It also improves coordination between SOC analysts, management, and other security teams.
- In real-world SOC environments, documentation is not optional—it is a critical part of incident response and compliance requirements.

1. Incident Reports



- An incident report is a formal document created after a security incident is detected, investigated, and resolved. It provides a complete record of what happened and how it was handled.
- Incident reports are used for audits, compliance checks, and management review.

2. Runbooks

- A runbook is a predefined step-by-step guide that explains how to handle specific types of security incidents. It helps SOC analysts respond quickly and consistently.
- Runbooks reduce confusion during incidents and ensure standard response actions are followed.

3. SOPs (Standard Operating Procedures)

- Standard Operating Procedures define the official rules and workflows followed by SOC teams for daily operations and incident handling.
- SOPs ensure consistency and standardization across the SOC team.

4. Post-Mortems (After Action Reports)

- A post-mortem is a detailed analysis conducted after an incident is resolved. It focuses on learning and improvement rather than just documentation.
- Post-mortems help improve future incident response and strengthen security posture.

• Practical application

1. Log Analysis Practice

• Objective

- The objective of this task was to practice security monitoring and forensic analysis using Windows logs and browser history artifacts.

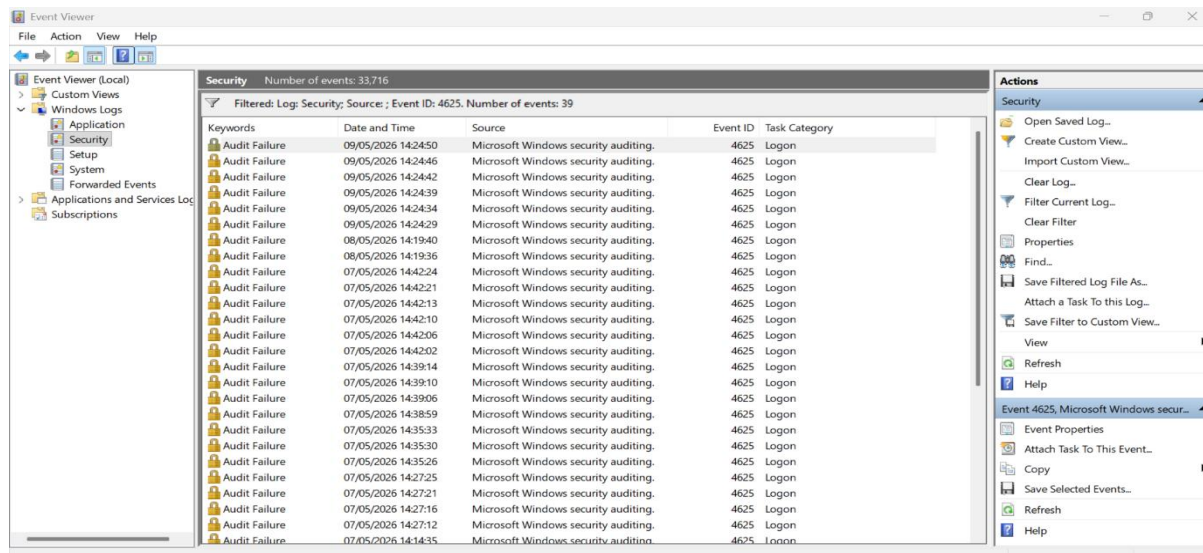
• Tool used

1. Windows Event Viewer
2. BrowserHistoryView
3. Google Chrome
4. Command Prompt

1. Windows Event Log Analysis

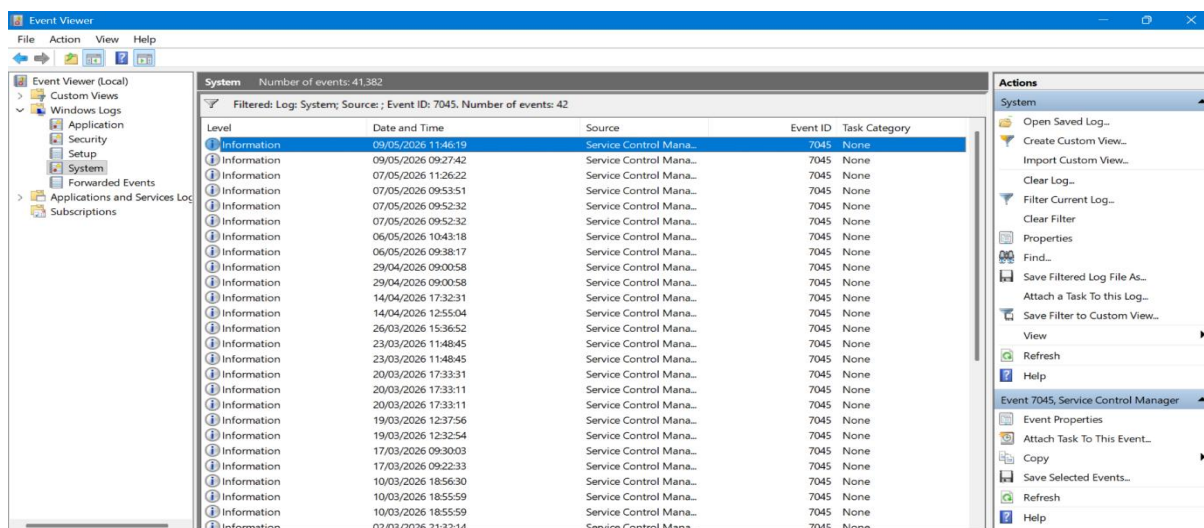
• Event ID 4625 – Failed Login Attempt

- Generated failed login attempts using: `runas /user:Administrator cmd`
- Multiple Event ID 4625 entries detected filtering security events



- **Event ID 7045 – New Service Creation**

- The logs contained:
 1. Newly installed services
 2. Service executable paths
 3. Startup type
 4. Service account information
- This event is important because attackers may create malicious services to maintain persistence within a system.





- Exported result to csv format

Level	Date and Time	Source	Event ID	Task Category	Details
Information	#####	Service Control Manager	7045	None	A service was installed in the system. Service Name: osqueryd Service File Name: "C:\Program Files\osquery\osqueryd.exe" -flagfile"C:\Program Files\osquery\osqueryd.exe" Service Type: user mode service Service Start Type: auto start Service Account: NT AUTHORITY\SYSTEM
Information	#####	Service Control Manager	7045	None	A service was installed in the system. Service Name: Tenable Nessus Service File Name: "C:\Program Files\Tenable\Nessus\nessus-service.exe" Service Type: user mode service Service Start Type: auto start Service Account: LocalSystem
Information	#####	Service Control Manager	7045	None	A service was installed in the system. Service Name: winlogbeat Service File Name: "C:\elasticsearch\winlogbeat-9.4.0-windows-x86_64\winlogbeat.exe" -environment=windows -service -c "C:\elasticsearch\winlogbeat-9.4.0-windows-x86_64\winlogbeat.yml" -path.home "C:\elasticsearch\winlogbeat-9.4.0-windows-x86_64" -path.data "C:\Program Files\Winlogbeat-Data\Winlogbeat" -path.logs "C:\Program Files\Winlogbeat-Data\Winlogbeat\logs" -E keystore.path="C:\elasticsearch\winlogbeat-9.4.0-windows-x86_64\data\Winlogbeat.keystore" -E logging.files.redirect_under=true Service Type: user mode service Service Start Type: auto start Service Account: LocalSystem
Information	#####	Service Control Manager	7045	None	A service was installed in the system. Service Name: GameInput Redist Service

2. Browser History Analysis

- To investigate browser activity and identify visits to suspicious or test URLs.
- LECmd is not designed to parse Chrome browser history directly. It is mainly used for parsing:
 - Windows .lnk shortcut files
 - Jump Lists
 - Recent file activity artifacts
- So using LECmd specifically for Chrome history analysis would not properly fit the task requirement.
- Instead of Eric Zimmerman's tools, BrowserHistoryView was used for browser history analysis.

URL	Title	Visit Time	Visit Count	Visited From	Visit Type	Visit Duration	Web Browser	User Profile
http://test1.com/	test1.com — slightly bett...	09/05/2026 22:56:57	1		Typed URL		Chrome	Public
http://test3.com/		09/05/2026 22:57:04	1		Typed URL		Chrome	Public
http://test4.com/	We show that quality me...	09/05/2026 22:57:16	3		Typed URL		Chrome	Public
http://test4.com/	We show that quality me...	09/05/2026 22:57:16	3	https://test4.com/	Typed URL		Chrome	Public
http://test4.com/	We show that quality me...	09/05/2026 22:57:16	3	https://test4.com/	Typed URL		Chrome	Public
http://test5.com/		09/05/2026 22:57:25	1		Typed URL		Chrome	Public
http://test6.com/	test6.com :: this domain i...	09/05/2026 22:57:36	1		Typed URL		Chrome	Public
https://accounts.google...	Google - My Activity	09/05/2026 22:55:33	1	https://myactivity.google...	Typed URL		Chrome	Public
https://myactivity.goo...	Google - My Activity	09/05/2026 22:55:33	2		Typed URL		Chrome	Public
https://myactivity.goo...	Google - My Activity	09/05/2026 22:54:53	2		Link		Chrome	Public
https://myactivity.goo...	Google - My Activity	09/05/2026 22:55:33	1	https://myactivity.google...	Typed URL		Chrome	Public
https://myactivity.goo...	Google - My Activity	09/05/2026 22:55:33	1	https://accounts.google...	Typed URL		Chrome	Public
https://myactivity.goo...	Google - My Activity	09/05/2026 22:54:53	4	https://myactivity.google...	Link	00:00:02.129	Chrome	Public
https://myactivity.goo...	Google - My Activity	09/05/2026 22:55:02	4		Link		Chrome	Public
https://myactivity.goo...	Google - My Activity	09/05/2026 22:54:57	4		Link	00:00:02.930	Chrome	Public
https://myactivity.goo...	Google - My Activity	09/05/2026 22:55:00	4		Link	00:00:01.943	Chrome	Public
https://myactivity.goo...	Google - My Activity	09/05/2026 22:54:55	1		Link	00:00:01.578	Chrome	Public



- Although the task instructions mentioned using LECmd from Eric Zimmerman's tools to analyze browser-related artifacts, LECmd is primarily designed for parsing Windows shortcut (.lnk) files and Jump List artifacts rather than directly parsing Chrome browsing history databases.
- For this task, the main objective was to identify visited URLs and analyze browser history activity from Google Chrome. Therefore, BrowserHistoryView was used because it is specifically designed to parse and display browser history records

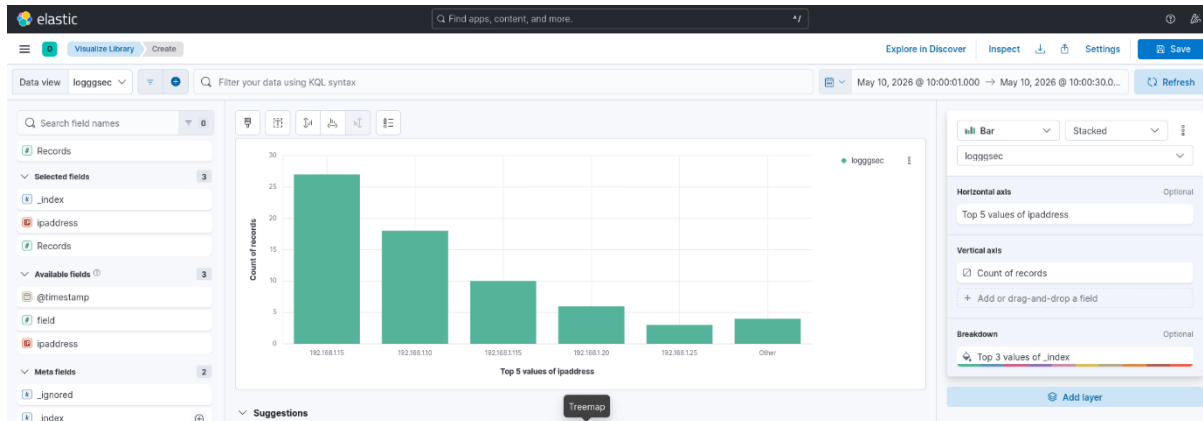
2. Document Security Events

Date/Time	Source IP	Event ID	Description	Action Taken
2026-05-09 16:45	192.168.1.10	4625	Multiple failed login attempts detected on Windows VM	Investigated logs and monitored for brute-force activity

- A suspicious security event was detected involving multiple failed login attempts from the IP address 192.168.1.10. The Windows system generated Event ID 4625, which indicates failed authentication attempts. The activity suggested a possible brute-force attack or unauthorized access attempt.
- reviewed the Windows Security logs, identified the source IP, and documented the event details including the timestamp, event ID, description, and response actions. The system was monitored for additional suspicious activity, and the event was recorded for future investigation and reporting purposes.

3. Set Up Monitoring Dashboards

- This graph helps identify IP addresses generating the highest number of alerts or suspicious activities.
- A new visualization was created using the Lens visualization tool available in Kibana.
- This graph helps identify IP addresses generating the highest number of alerts or suspicious activities.



4. Configuring Alert Rules

- A detection rule was configured in Elastic SIEM to identify brute-force login attempts by monitoring failed authentication events (Event ID 4625). The rule triggers an alert when more than five failed login attempts occur within a five-minute window from the security-login-* index. The rule was tested by simulating repeated failed SSH login attempts. This configuration demonstrates how SIEM-based alerting enables automated detection of suspicious authentication behavior, improving SOC response efficiency and threat visibility.

The figure is a screenshot of the Elasticsearch Kibana 'Configure Alert Rules' interface. It shows the '1. Define rule' section with the following details: Rule name: Detect 5+ failed logins in 5 minutes; Index patterns: security-login-*; Rule type: Elasticsearch query. The '2. Define query' section shows a KQL query:

```
1 {
2   "query": {
3     "bool": {
4       "filters": [
5         { "term": { "event.category": "login_failure" } }
6       ]
7     }
8   }
9 }
10
```

 The '3. Set rule schedule' section shows the rule condition: Count is above 5 for 5 minutes. The 'Rule summary' section on the right shows the rule type (Elasticsearch query), severity (High), risk score (75), action (Create alert), schedule (Every 5 minutes), and additional test-break time (5 minutes). The 'Last updated' timestamp is May 14, 2024 @ 10:15:23.

• Custom Alert Rule in Wazuh SIEM

- which generated multiple failed login attempts on the target system. These attempts were recorded in the authentication logs and imported into wazuh for analysis.

• Command used



1. **sudo bash wazuh-install.sh -a**
 - to install wazuh
 2. **sudo nano /var/ossec/etc/rules/local_rules.xml**
 - to add Alert rule in xml file
 3. **ssh sshuser@127.0.0.1**
 - to create failed login attempts
- **xml rule file**

```
GNU nano 8.7 /var/ossec/etc/rules/local_rules.xml
group name="custom_ssh_bruteforce,">
<rule id="100100" level="10" frequency="3" timeframe="120">
<if_matched_sid>5710</if_matched_sid>
<same_source_ip />
<description>Multiple failed SSH login attempts detected</description>
<mitre>
<id>T1110</id>
</mitre>
</rule>
</group>
```

- **attempted failed SSH logins**

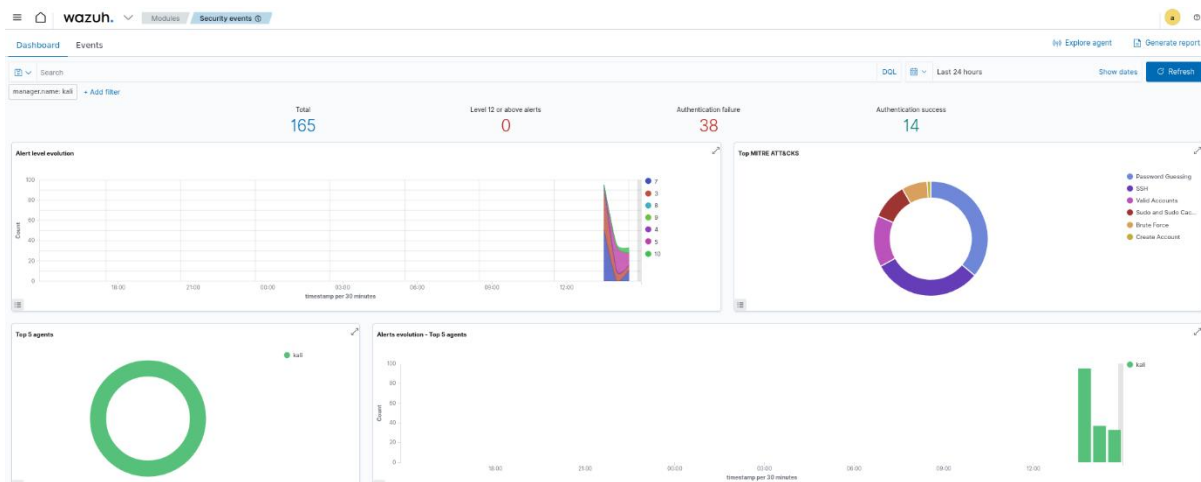
```
(root@kali)-[/home/kali]
# ssh sshuser@127.0.0.1
sshuser@127.0.0.1's password:
Permission denied, please try again.
sshuser@127.0.0.1's password:
Permission denied, please try again.
sshuser@127.0.0.1's password:
sshuser@127.0.0.1: Permission denied (publickey,password).

(root@kali)-[/home/kali]
# ssh sshuser@127.0.0.1
sshuser@127.0.0.1's password:
Permission denied, please try again.
sshuser@127.0.0.1's password:
Permission denied, please try again.
sshuser@127.0.0.1's password:
sshuser@127.0.0.1: Permission denied (publickey,password).

(root@kali)-[/home/kali]
#
```



- **wazuh ui**



- **Verifying alert**

Security Alerts							
Time	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
May 10, 2026 @ 14:43:03.814	000	kali	T1110.001 T1021.004	Credential Access, Lateral Movement	sshd: Attempt to login using a non-existent user	5	5710
May 10, 2026 @ 14:43:02.195	000	kali	T1110.001 T1021.004	Credential Access, Lateral Movement	sshd: Attempt to login using a non-existent user	5	5710
May 10, 2026 @ 14:43:02.194	000	kali	T1110.001 T1021.004	Credential Access, Lateral Movement	sshd: Attempt to login using a non-existent user	5	5710
May 10, 2026 @ 14:42:59.810	000	kali	T1110.001 T1021.004	Credential Access, Lateral Movement	sshd: Attempt to login using a non-existent user	5	5710
May 10, 2026 @ 14:42:59.810	000	kali	T1110	Credential Access	Multiple failed SSH login attempts detected	10	100100
May 10, 2026 @ 14:42:59.810	000	kali	T1110.001 T1021.004	Credential Access, Lateral Movement	sshd: Attempt to login using a non-existent user	5	5710
May 10, 2026 @ 14:42:57.818	000	kali	T1110.001 T1021.004	Credential Access, Lateral Movement	sshd: Attempt to login using a non-existent user	5	5710
May 10, 2026 @ 14:42:55.792	000	kali	T1110	Credential Access	Multiple failed SSH login attempts detected	10	100100
May 10, 2026 @ 14:42:55.792	000	kali	T1110.001 T1021.004	Credential Access, Lateral Movement	sshd: Attempt to login using a non-existent user	5	5710
May 10, 2026 @ 14:42:23.665	000	kali	T1110	Credential Access	Multiple failed SSH login attempts detected	10	100100

- The lab successfully demonstrates how Wazuh SIEM can detect brute-force SSH attacks using authentication log monitoring. Even without custom frequency rules, Wazuh effectively correlates multiple failed login events using built-in rule 5716.
- This setup is useful for SOC environments to detect unauthorized access attempts in real time and supports early incident response.

- **Key learnings**

- Learned the overall workflow and responsibilities inside a Security Operations Center (SOC).
- Understood how SIEM tools collect, normalize, and analyze logs for threat detection.



- Learned how to use KQL queries to investigate failed login attempts and suspicious activity.
- Gained practical experience in creating dashboards and visualizations for security monitoring.
- Understood the importance of log normalization and structured data formats like JSON.
- Learned how brute-force attacks can be detected through authentication logs and source IP analysis.
- Understood how alert rules and Sigma-style detections help automate security monitoring.
- Improved troubleshooting skills while handling Kibana, Elasticsearch, and log ingestion issues.

• Challenges faced

- Difficulty configuring Kibana and reconnecting it with Elasticsearch after service failures.
- Log files initially failed to upload because of timestamp and formatting issues.
- SSH failed login simulation did not work initially due to the SSH service being disabled.
- KQL queries were not accepted because of incorrect syntax and unsupported fields.
- Creating structured visualizations for source IP monitoring required proper field mapping and normalization.
- Some logs were unstructured, making dashboard creation and filtering difficult.

• Summary

This task focused on understanding SOC operations, security monitoring, log management, incident response, and SIEM-based threat detection. A mini SOC lab was created using Elastic Stack and Kibana to collect, analyze, and visualize security logs. Practical activities included log analysis, failed login detection, dashboard creation, KQL querying, alert monitoring, and IOC-based threat hunting. The task also covered documentation standards, security workflows, and use of detection logic similar to Sigma rules for monitoring suspicious activity.

• References

- [Elastic Stack Documentation](#)
- [Kibana Guide](#)
- [Elasticsearch Reference](#)
- [MITRE ATT&CK Framework](#)
- [NIST SP 800-61 Incident Response Guide](#)
- Wazuh Documentation
- [Sigma Detection Rules](#)



- [Short Documentation](#)
- Osquery Documentation
- [Microsoft Event ID Reference](#)